Larkspur Mutual - Outsourcing, Security and Resilience Requirements

Appendix D to the Claims Platform RFP. Applies to the supplier and its subcontractors.

Outsourcing and regulation

- The claims platform is a critical or important function. Larkspur will notify the regulator before contract signature; the supplier supports the notification with its own documentation.
- Larkspur and the regulator have unrestricted rights to audit the supplier, including on-site.
- An exit plan must allow Larkspur to move to another provider within 12 months, with all data returned in an open format.
- Subcontracting of any part of the service needs Larkspur's prior written approval.

Information security

- ISO 27001 certified supplier, or SOC 2 Type II report no older than 12 months.
- Annual penetration test by an independent firm; results shared with Larkspur.
- Card data is never stored. If members pay excess by card, a PCI DSS compliant payment page hosted by the payment provider is used.
- Privileged access through Larkspur's bastion with session recording.

Resilience

- Recovery time objective 4 hours, recovery point objective 15 minutes.
- Annual disaster recovery test with Larkspur observing.
- ICT incidents classified and reported to Larkspur within 4 hours for major incidents.

Data protection

- Supplier acts as processor under GDPR. Data stays in the EU, including support access from outside the EU (none allowed without approval).
- Personal data in test environments must be anonymised.